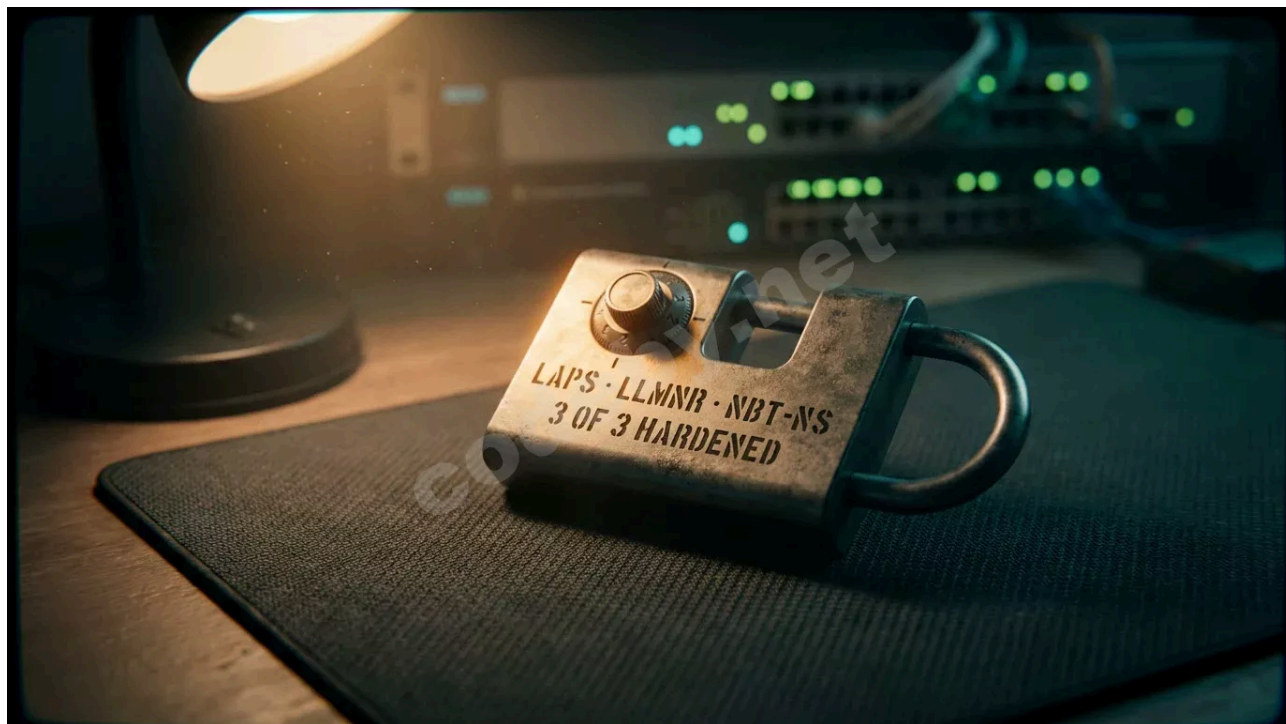


Статья Харденинг Active Directory: LAPS, LLMNR и NBT-NS — три меры против 80% внутренних атак

 codeby.net/threads/khardening-active-directory-laps-llmnr-i-nbt-ns-tri-mery-protiv-80-vnutrennikh-atak.92656

April 14, 2026

[Добавить закладку](#)



На каждом внутреннем пентесте первые полчаса выглядят одинаково: подключение к пользовательскому VLAN, запуск Responder, ожидание. В среде без харденинга Active Directory первый NTLMv2-хеш прилетает быстрее, чем заваривается кофе. Дальше - hashcat, credential stuffing, lateral movement, и через пару часов у тебя Domain Admin. Каждый. Раз. - полный путь от разведки до DCSync с инструментами и техниками я разобрал в [гайде по пентесту Active Directory](#).

По данным Microsoft Digital Defense Report (на который ссылается Semperis), почти половина инцидентов, расследуемых Microsoft Incident Response, содержала небезопасные конфигурации Active Directory. Mandiant подтверждает: 9 из 10 кибератак эксплуатируют AD. При этом три меры - отключить LLMNR, выполнить NBT-NS disable и провести LAPS настройку - закрывают основные векторы credential harvesting, за которые атакующий хватается в первые часы внутреннего пентеста.

Здесь не будет теории ради теории. Конкретные команды, GPO-пути, ключи реестра, проверки и грабли, на которые я лично наступал при развёртывании харденинга AD в

инфраструктурах от 200 до 3000 машин.

Что видит атакующий в сети без харденинга AD

Прежде чем закрывать дыры, стоит понять, как именно они эксплуатируются.

Безопасность Active Directory начинается с понимания атаки - иначе тычинишь не то и не там.

LLMNR/NBT-NS poisoning - credential harvesting за минуты

LLMNR (Link-Local Multicast Name Resolution) и NBT-NS (NetBIOS Name Service) - fallback-протоколы. Когда DNS не может разрешить имя хоста, Windows шлёт широковещательный запрос в локальную сеть: «Кто знает, где находится сервер FILESHRE?» (опечатка пользователя). Проблема: у этих протоколов нет механизма аутентификации - ответить может кто угодно.

Атакующий запускает Responder и ждёт. Как только жертва пытается обратиться к несуществующему ресурсу - а это происходит постоянно из-за опечаток, устаревших ярлыков, отключённых серверов - Responder отвечает: «Это я, аутентифицируйся». Жертва послушно отправляет NTLMv2-хеш учётной записи.

По классификации MITRE ATT&CK это техника LLMNR/NBT-NS Poisoning and SMB Relay ([T1557.001](#), тактики: Credential Access, Collection). Отдельно стоит упомянуть Forced Authentication (T1187, Credential Access) - принуждение к аутентификации через вредоносные файлы (.lnk, .scf, .url с UNC-путями). Она может использоваться совместно с Responder для генерации трафика, но это самостоятельный вектор, а не часть poisoning-сценария.

Запуск Responder на практике - команда из материалов TCM Security:

```
sudo responder -I eth0 -dwP
```

После перехвата хеша атакующий получает IP жертвы, домен, имя пользователя (например, CORP\ivanov) и NTLMv2-хеш. Дальше - офлайн-брутфорс через hashcat:

```
hashcat -m 5600 captured_hash.txt wordlist.txt
```

Модуль 5600 - это именно NTLMv2. Слабый или словарный пароль падает за секунды. Пароль 8–10 символов из стандартного набора - за минуты-часы в зависимости от железа.

Один хеш - полный lateral movement по домену

Допустим, пароль не крякнулся. Атакующий не остановился. В средах без LAPS Active Directory все рабочие станции обычно живут с одинаковым паролем локального администратора - он задаётся через групповые политики или образ. Один скомпрометированный хеш локального админа открывает доступ ко всем машинам через [Pass the Hash](#) (T1550.002, тактики: Defense Evasion, Lateral Movement). CrackMapExec проходит по всей подсети за секунды, собирает SAM-базы, находит привилегированные учётки.

Другой сценарий: пароль всё-таки крякнулся, и это доменная учётка с правами локального администратора. Тут уже не PtH, а использование валидных учётных данных - Valid Accounts (T1078, тактики: Defense Evasion, Persistence, Privilege Escalation, Initial Access). Lateral movement становится тривиальным: атакующий аутентифицируется на машинах напрямую, и через пару прыжков оказывается на контроллере домена.

Именно поэтому защита Active Directory начинается с трёх конкретных мер, а не с покупки дорогого SIEM.

Отключить LLMNR - первый шаг LLMNR poisoning защиты

Отключение LLMNR - самая простая из трёх мер и одна из самых эффективных. В среде с работающим DNS отключение LLMNR не вызывает вообще никаких проблем. Лично я начинаю харденинг всегда с неё - пять минут работы, а целый вектор отваливается.

Настройка через групповую политику

Путь в Group Policy Management Editor:

Computer Configuration → Policies → Administrative Templates → Network → DNS Client → Turn off multicast name resolution → Enabled

Если нужно управлять через реестр напрямую (для Intune или других MDM), ключ следующий (рекомендация Microsoft TechCommunity):

```
HKLM\Software\Policies\Microsoft\Windows NT\DNSClient  
EnableMulticast = 0 (REG_DWORD)
```

После применения GPO каждая рабочая станция перестанет отправлять широковещательные LLMNR-запросы. Responder больше не получит NTLMv2-хеши через этот вектор.

Верификация отключения LLMNR

После применения политики проверяем на рабочей станции через PowerShell (команда из TCM Security):

```
(Get-ItemProperty -Path "HKLM:\Software\Policies\Microsoft\Windows NT\DNSClient" -Name EnableMulticast).EnableMulticast
```

Ожидаемый результат: 0. Если вернулась 1 или ключ отсутствует - политика не применилась, копайте `gpresult /r`.

NBT-NS disable - подводные камни отключения NetBIOS

С NBT-NS всё веселее. Отключить NBT-NS Windows можно несколькими способами, но не все из них одинаково надёжны в масштабе.

Почему отключение через NIC не масштабируется

Стандартная рекомендация - зайти в свойства сетевого адаптера, TCP/IPv4 → Advanced → WINS → Disable NetBIOS over TCP/IP. Проблема: настройка привязана к конкретному адаптеру. У каждого NIC свой GUID в реестре, и при добавлении нового адаптера (VPN-клиент, Wi-Fi, Docker) настройка не наследуется. В среде из 500+ машин ручное управление per-NIC - утопия.

NodeType P-node через реестр - правильный подход

Решение из серии Active Directory Hardening от Microsoft TechCommunity - установить NetBT NodeType в режим P-node на уровне хоста. В P-node клиент использует только WINS для разрешения NetBIOS-имён и полностью отключает широковещание. Поскольку WINS-серверов в современных средах нет (и не должно быть), NetBIOS name resolution фактически перестаёт работать:

```
HKLM\SYSTEM\CurrentControlSet\Services\NetBT\Parameters  
NodeType = 2 (REG_DWORD)
```

Нативной GPO-настройки для NodeType нет, но в Microsoft Security Compliance Toolkit есть файл `SecGuide.admx`, который добавляет административный шаблон MS Security Guide с настройкой NetBT NodeType configuration.

Альтернативный подход для NBT-NS (упомянут в материалах ProjectBlack) - через ключ DNS-клиента:

```
HKLM\SYSTEM\CurrentControlSet\Services\Dnscache\Parameters  
EnableNetbios = 0 (REG_DWORD)
```

Альтернатива - startup script для legacy-систем

Для старых версий Windows, где реестровые ключи Dnscache не поддерживаются, используется PowerShell startup script. Метод описан и у TCM Security, и у Blumira:

```
Set-ItemProperty -Path  
HKLM:\SYSTEM\CurrentControlSet\services\NetBT\Parameters\Interfaces\tcpip* -Name  
NetbiosOptions -Value 2
```

Скрипт применяется через GPO:

Computer Configuration → Policies → Windows Settings → Scripts → Startup

Скрипт нужно разместить в SYSVOL - чтобы он был доступен всем клиентам при загрузке.

Нюанс: Startup script применяется при каждой загрузке и затрагивает все интерфейсы, существующие на момент старта. Для адаптеров, создаваемых после загрузки (VPN, Docker), настройка не применится до следующей перезагрузки. Для полного покрытия комбинируйте startup script с NodeType=2, который действует глобально.

Верификация отключения NBT-NS через cmd:

```
wmic nicconfig get caption,index,TcpipNetbiosOptions
```

Ожидаемое значение TcpipNetbiosOptions = 2 для всех адаптеров.

LAPS настройка - уникальные пароли локальных администраторов

Отключение LLMNR и NBT-NS убирает Responder-вектор. Но даже без Responder атакующий может получить хеш локального администратора другими путями - дамп SAM после физического доступа, уязвимость в сервисе, любой другой credential harvesting AD. Если пароль локального админа одинаковый на всех машинах - одного хеша достаточно для Pass the Hash по всему домену.

Local Administrator Password Solution (LAPS) решает эту проблему: каждая машина получает уникальный, автоматически ротируемый пароль локального администратора, который хранится в атрибутах объекта компьютера в AD.

Зачем нужен LAPS и что он заменяет

До LAPS администраторы часто управляли паролями локальных админов через [Group Policy Preferences](#) (GPP). Пароль задавался в GPP и хранился в SYSVOL в XML-файле, зашифрованном AES-ключом. А теперь внимание: ключ AES-256 был включён в открытую документацию протокола (MS-GPPREF) на MSDN. Шифрование - бесполезное. Любой доменный пользователь может прочитать файл Groups.xml из

SYSVOL и расшифровать пароль с помощью этого ключа. [MS14-025](#) запретил создание новых GPP с встроенными паролями, но не удалил существующие - их надо удалять вручную. По MITRE ATT&CK это техника Group Policy Preferences (T1552.006, Credential Access).

Я до сих пор нахожу GPP-пароли в SYSVOL на проектах. В 2025 году. Серьёзно.

LAPS заменяет этот небезопасный механизм. Атрибут с паролем в AD защищён ACL - только авторизованные учётки могут его прочитать.

Legacy LAPS vs Windows LAPS

Legacy LAPS требовал отдельной установки MSI-пакета на каждую рабочую станцию и расширения схемы AD (атрибуты ms-Mcs-AdmPwd и ms-Mcs-AdmPwdExpirationTime). Windows LAPS встроен в ОС начиная с обновлений апреля 2023 года для Windows 10 21H2+ и Windows Server 2019+. Он использует атрибут msLAPS-Password и поддерживает шифрование пароля, резервное копирование в Azure AD и историю паролей.

Для сред, где ещё живут машины на Windows 7/Server 2012 - legacy LAPS остаётся единственным вариантом. В гетерогенных средах может потребоваться одновременное использование обеих версий (и это отдельная головная боль с делегированием).

Развёртывание LAPS пошагово

Порядок действий для развёртывания Windows LAPS:

Шаг 1: обновление схемы AD. На контроллере домена с правами Schema Admin:

```
Update-LapsADSchema
```

Шаг 2: назначение разрешений для компьютеров. Компьютеры должны иметь право записи своего пароля в собственный объект:

```
Set-LapsADComputerSelfPermission -Identity "OU=Workstations,DC=corp,DC=local"
```

Шаг 3: настройка GPO. Путь к политикам LAPS:

Computer Configuration → Policies → Administrative Templates → System → LAPS

Ключевые параметры:

Параметр	Рекомендация
Configure password backup directory	Active Directory
Password complexity	Большие + малые буквы + цифры + спецсимволы
Password length	20+ символов
Password age	30 дней
Name of administrator account to manage	Оставить пустым (управляет встроенным Administrator)

Шаг 4: делегирование прав на чтение паролей. Определите, кто должен читать пароли LAPS - обычно это группа helpdesk или отдельная группа безопасности:

```
Set-LapsADReadPasswordPermission -Identity "OU=Workstations,DC=corp,DC=local" -
AllowedPrincipals "CORP\LAPS-Readers"
```

Шаг 5: проверка работоспособности. После применения GPO и перезагрузки рабочей станции:

```
Get-LapsADPassword -Identity "WS-001" -AsPlainText
```

Если пароль возвращается - LAPS работает. Если нет - смотрите Event Log на рабочей станции (источник LAPS) и проверяйте права делегирования.

Верификация харденинга: до и после глазами атакующего

Харденинг AD без проверки - самообман. Покажу, что конкретно меняется для атакующего после внедрения трёх мер.

Responder после отключения LLMNR и NBT-NS

До харденинга запуск `sudo responder -I eth0 -dwP` даёт поток хешей. После отключения LLMNR и NBT-NS Responder молчит. Буквально - лог пустой, событий нет. Broadcast-запросы не отправляются, отвечать не на что.

Но есть нюанс. Если хотя бы одна машина не получила GPO (выключена, вне сети, потеряла связь с DC), она продолжит отправлять LLMNR/NBT-NS-запросы. Поэтому после внедрения я всегда провожу контрольный запуск Responder в пассивном режиме (`responder -I eth0 -A`) на 24 часа - и проверяю, есть ли оставшийся

трафик. На одном проекте так нашли 12 машин, которые полгода не видели контроллер домена.

CrackMapExec после внедрения LAPS

До LAPS lateral movement через Pass the Hash выглядит так: один хеш локального админа → CrackMapExec проходит по всей подсети с результатом Pwn3d! на каждой машине. Красота (для атакующего).

После внедрения LAPS каждый хеш работает только на одной конкретной машине. CrackMapExec на соседних хостах возвращает STATUS_LOGON_FAILURE. Lateral movement через локального администратора - остановлен.

Проверочная команда (от лица пентестера, для демонстрации):

```
# пример для демонстрации концепции  
crackmapexec smb 10.0.0.0/24 -u Administrator -H <hash> --local-auth
```

Без LAPS - зелёные строки Pwn3d! по всей подсети. С LAPS - одна зелёная строка (если хеш вообще валиден) и десятки красных.

Грабли и edge-cases при развёртывании

GPO-конфликты и legacy-системы

На проектах по харденингу я регулярно наступаю на одни и те же грабли:

Конфликты GPO. Если в домене уже есть политика, которая задаёт пароль локального администратора через GPP - она будет конфликтовать с LAPS. GPP перезапишет пароль поверх того, что установил LAPS. Решение: удалить все GPP с паролями до развёртывания LAPS. Проверить наличие GPP-паролей можно утилитой Get-GPPPassword из PowerSploit или ручным поиском crassword в XML-файлах SYSVOL.

Legacy-системы без поддержки LAPS. Windows XP, Server 2003, а в некоторых средах даже Server 2008 без SP - не поддерживают ни одну версию LAPS. Для этих машин остаётся ручная ротация или скриптовый подход, но главное - они должны быть изолированы в отдельный VLAN с минимальными правами. Если у вас в 2025 году Server 2003 в продуктиве - LAPS не самая большая ваша проблема.

Делегирование прав - типичная ошибка. Администраторы часто дают право чтения LAPS-паролей группе Domain Admins и забывают про helpdesk. Или наоборот - дают helpdesk права на все OU, включая серверные. Правильный подход: отдельные группы для разных OU (LAPS-Readers-Workstations, LAPS-Readers-Servers) с минимально необходимым scope.

Шифрование паролей LAPS. Windows LAPS поддерживает шифрование паролей в AD - атрибут хранится в зашифрованном виде, расшифровать может только авторизованный пользователь. Legacy LAPS хранит пароль в открытом виде в атрибуте ms-Mcs-AdmPwd - любой, кто имеет право чтения этого атрибута, видит пароль как на ладони. Проверьте делегирование через BloodHound: узел компьютера → ReadLAPSPassword edge.

Когда LLMNR нельзя отключить полностью

Бывает, что полное отключение невозможно. По данным Blumira, многие legacy-продукты полагаются на широковещательное разрешение имён. В таких случаях - альтернативные меры:

- Network Access Control (NAC) - ограничение того, кто может отвечать на широковещательные запросы
- Принудительная сложность паролей - длина 14+ символов делает крекинг NTLMv2-хешей значительно затратнее
- SMB Signing - даже если атакующий перехватит хеш, relay-атака не сработает при обязательной подписи SMB

Подпись SMB заслуживает отдельного упоминания. Как описано в серии AD Hardening от Microsoft TechCommunity, SMB signing предотвращает NTLM Relay: атакующий не знает учётных данных жертвы и не может подписать SMB-пакеты сессионным ключом. Включение обязательной подписи SMB - четвёртая мера, которую стоит внедрить сразу после первых трёх.

Дополнительный вектор: mDNS

Помимо LLMNR и NBT-NS, ProjectBlack рекомендует отключать mDNS (Multicast DNS) - ещё один протокол обнаружения, который можно использовать для poisoning:

```
HKLM\SYSTEM\CurrentControlSet\Services\Dnscache\Parameters  
EnableMDNS = 0 (REG_DWORD)
```

Отключение mDNS может повлиять на обнаружение устройств в сети - Chromecast, беспроводные принтеры и другие сервисы на базе Bonjour/Avahi. Тестируйте перед массовым развёртыванием, иначе helpdesk завалят тикетами «принтер пропал».

Сводная таблица: три меры харденинга Active Directory

Мера	Вектор атаки	MITRE ATT&CK	Сложность внедрения	Влияние на инфраструктуру
Отключить LLMNR	LLMNR Poisoning	T1557.001	Низкая (один параметр GPO)	Минимальное при работающем DNS
NBT-NS disable	NBT-NS Poisoning	T1557.001	Средняя (реестр / startup script)	Низкое в современных средах
LAPS настройка	Pass the Hash, credential reuse	T1550.002, T1552.006	Средняя (схема + GPO + делегирование)	Изменение процесса сброса паролей

Порядок внедрения для практиков

Если ты только начинаешь харденинг AD - вот порядок, который я использую на проектах:

1. **Аудит текущего состояния.** Запусти Responder в режиме анализа (-A) на 24 часа. Посмотри объём broadcast-трафика. Проверь наличие GPP-паролей в SYSVOL.
2. **Отключи LLMNR.** Минимальный риск, максимальный эффект. Одна GPO, применяется на весь домен.
3. **Отключи NBT-NS.** Используй NodeType=2 через реестр для современных систем, startup script для legacy.
4. **Разверни LAPS.** Начни с пилотной OU (50–100 машин), проверь работу, затем масштабируй.
5. **Включи обязательную подпись SMB.** Закрывает NTLM Relay даже если атакующий найдёт другой способ перехвата.
6. **Проведи контрольный пентест.** Запусти Responder и CrackMapExec повторно. Убедись, что вектора закрыты.

Эти шесть действий не требуют покупки дополнительного ПО (Windows LAPS встроен в ОС), не нуждаются в сложной архитектуре и закрывают основные векторы credential harvesting на начальном этапе внутреннего пентеста. Но они не покрывают ряд распространённых техник: Kerberoasting (T1558.003), AS-REP Roasting (T1558.004), NTLM Relay на не-SMB протоколы без Extended Protection for Authentication, DCSync (T1003.006) и атаки на misconfigured ADCS (ESC1–ESC8). Это - следующие шаги харденинга.

Безопасность Active Directory - не про дорогие решения. Это про последовательный харденинг, который почему-то до сих пор не сделан в большинстве доменов. Запусти Responder в своей сети прямо сейчас - и посмотри, сколько хешей прилетит за час. Если ответ «ноль» - поздравляю, ты в меньшинстве.

Последнее редактирование: